

In 2013 and 2014, Yahoo, an American web services company, experienced two of the largest data breaches in history—yet despite being aware, the company did not disclose them publicly until September 2016.

The 2013 data breach occurred on Yahoo servers in August 2013 and affected all three billion user accounts. The 2014 breach affected over 500 million user accounts. Both breaches are considered the largest ever discovered and included names, email addresses, phone numbers, birth dates, and security questions—both encrypted and unencrypted. When Yahoo made the breaches public in 2016, they acknowledged being aware of the second intrusion since 2014.

These incidents led to the indictment of four individuals linked to the latter breach, including the Canadian hacker Karim Baratov who received a five-year prison sentence and also prompted widespread criticism of Yahoo for their delayed response. The fallout included a U.S. \$117.5 million class-action lawsuit settlement, a \$35 million fine from the U.S. Securities and Exchange Commission, scrutiny by the United States Congress, and complications for Verizon Communication's 2017 acquisition of Yahoo.

August 2013: breach

The first data breach occurred on Yahoo servers in August 2013 and affected all three billion user accounts. Yahoo announced the breach on December 14, 2016. Marissa Mayer, who was CEO of Yahoo at the time of the breach, testified before Congress in 2017 that Yahoo had been unable to determine who perpetrated the 2013 breach.

Early 2014: security culture at Yahoo

A year after Yahoo was identified by the American whistleblower Edward Snowden as a frequent target for state-sponsored hackers in 2013, the company hired a dedicated chief information security officer, Alex Stamos. While Stamos' hiring was praised by technology experts as showing Yahoo's commitment towards better security, Yahoo CEO Marissa Mayer

had reportedly denied Stamos and his security team sufficient funds to implement the security measures they recommended, and he departed the company by 2015.

Late 2014: breach

During November or December 2014 a hacker, believed by the U.S. Justice Department to be the Russian national Alexey Belan, copied a November 2014 backup of Yahoo's User Account Database, containing details of over 500 million accounts to a computer under his control. The User Account Database included data from over 500 million user accounts, including account names, email addresses, telephone numbers, dates of birth, hashed passwords, and in some cases, encrypted or unencrypted security questions and answers through manipulated web cookies. The majority of Yahoo's passwords used the bcrypt hashing algorithm, which is considered difficult to crack, with the rest potentially using older algorithms such as the MD5 algorithm, which could be broken rather quickly.

From October 2014 to at least November 2016, Belan and at least two hackers connected to him accessed user account information and contents for various unlawful actions including searching emails for gift voucher codes, deliberately targeting the accounts of persons of interest, improving the search ranking of businesses they had an interest in, and using the Yahoo data to breach accounts on other platforms such as Gmail. As part of this process, the hackers enlisted Canadian hacker Karim Baratov to break into accounts on other platforms.

July 2016 to October 2017: public disclosures

In June 2016, it was reported that account names and passwords for about 200 million Yahoo accounts were presented for sale on the darknet market site TheRealDeal. Yahoo stated it was aware of the data and was evaluating it, cautioning users about the situation but did not reset account passwords at that time.

Yahoo officially reported the 2014 breach to the public on September 22, 2016. Yahoo's

actions to deal with the breach included invalidating unencrypted security questions and answers and asking potentially affected users to change their passwords. Yahoo also claimed that there was no evidence that the attackers were still in the system and that the attack was state-sponsored. The Federal Bureau of Investigation (FBI) confirmed that it was investigating the matter. The Wall Street Journal reported that a security firm, which had access to a portion of Yahoo's database, believed that the attackers were criminal in nature rather than state sponsored, and that the database had been sold repeatedly.

In its November 2016 U.S. Securities and Exchange Commission (SEC) filing, Yahoo reported they had been aware of an intrusion into its network in 2014, but had not understood the extent of the breach until it began an investigation of a separate data breach incident around July 2016. Yahoo's previous SEC filing on September 9, prior to the breach announcement, had stated that it was not aware of any "security breaches" or "loss, theft, unauthorized access or acquisition" of user data. The November filing noted that the company believed one of the data breaches had been conducted through a cookie-based attack that allowed hackers to authenticate as any other user without their password. (In an SEC regulatory filing in 2017, Yahoo reported that 32 million accounts were accessed through this cookie-based attack through 2015 and 2016.)

In December 2016, Yahoo disclosed the 2013 breach, and that one billion user accounts had been compromised. Almost a year later, in October 2017 they revised that estimate and reported that all three billion Yahoo accounts had been compromised in the breach.

Yahoo's internal review of the situation found that Mayer and other key executives knew of the intrusions but failed to inform the company or take steps to prevent further breaches. The review led to the resignation of the company's General Counsel, Ronald S. Bell by March 2017, and Mayer's \$12 million equity compensation and bonus for 2016 and 2017 was pulled.

Prosecution

On March 15, 2017, the FBI charged four men with the 2014 breach, including two that were working for Russia's Federal Security Service (FSB). In its statement, the FBI said "The criminal conduct at issue, carried out and otherwise facilitated by officers from an FSB unit that serves as the FBI's point of contact in Moscow on cybercrime matters, is beyond the pale."

The four men accused include hacker Alexsey Belan who was on the FBI Ten Most Wanted Fugitives list, FSB agents Dmitry Dokuchaev and Igor Sechin who the FBI accused of paying Belan and other hackers to conduct the hack, and Canadian hacker Karim Baratov. The FBI claimed that Dokuchaev and Sushchin paid Karim Baratov to use data obtained by the Yahoo breaches to break into about 80 non-Yahoo accounts of specific targets. Russian officials have denied any involvement.

Baratov, the only man arrested, was extradited to the United States in August 2017. He pled guilty, admitting to hacking into at least 80 email accounts on behalf of Russian contacts. He was charged with nine counts of hacking, and in May 2018 sentenced to 5 years in prison and ordered to pay \$2.25 million and restitution to his victims. His memoir, published in 2023, describes a party lifestyle funded by hacking into email accounts of thousands of people.

Reactions and criticism

Yahoo's delay in discovering and reporting these breaches, as well as implementing improved security features, has been roundly criticized at all levels.

Verizon Communications deal

Before the announcement of the breaches Verizon Communications had entered into negotiations and approval to purchase a portion of the Yahoo properties for \$4.8 billion, with the deal set to close in March 2017. Yahoo only disclosed the 2014 breach to Verizon two days prior to the Yahoo's September announcement. Verizon CEO Lowell McAdam said he wasn't shocked by the hack, saying "we all live in an internet world, it's not a question of if you're

going to get hacked but when you are going to get hacked". In February 2017, Verizon and Yahoo announced that the deal will still go forward, but dropping the sale price by \$350 million, down to \$4.48 billion. The deal officially closed at this price in June 2017, with Mayer stepping down as CEO following the closure. Verizon and Yahoo agreed to jointly share ongoing costs for the government investigation of the breaches under this new term. The Yahoo company, which still held those properties not purchased by Verizon, was renamed to Altaba in June 2017. As Altaba was the original company, it was Altaba that was subject to a later \$35 million fine from the SEC rather than Verizon.

United States government

In a letter to Mayer, six U.S. Senators (Elizabeth Warren, Patrick Leahy, Al Franken, Richard Blumenthal, Ron Wyden and Ed Markey) demanded answers on when Yahoo discovered the last 2014 breach, and why it took so long to disclose it to the public, calling the time lag between the security breach and its disclosure "unacceptable". On September 26, 2016, senator Mark Warner asked the U.S. Securities and Exchange Commission (SEC) to investigate whether Yahoo and its senior executives fulfilled their obligations under federal securities laws to properly disclose the attack. In 2018, the SEC announced a \$35 million fine against Altaba for failure to disclose the 2014 breach in a timely manner.

Class action lawsuits

In November 2016, it was reported that 23 lawsuits related to the late 2014 breach had been filed against Yahoo. In one lawsuit, filed in the U.S. District Court for the Southern District of California in San Diego, the plaintiffs contended that the hack caused an "intrusion into personal financial matters."

Five of these 23 cases were combined into a single suit in early December 2016. The case was later amended to include the updated breach information following Yahoo's announcement

about the August 2013 breach. Before a trial could commence, Verizon and Altaba agreed to split the cost of a \$50 million settlement in October 2018 with those in the class action (an estimated 200 million total users), along with providing two years of free credit monitoring. The judge rejected the settlement offer, questioning the lack of transparency of the details of the settlements, as well as high costs recouped by the lawyers through the settlement. Yahoo agreed to settle for \$117.5 million in April 2019, again offering affected users credit monitoring and a cash payout that depended on the number of respondents in the class.

International

Foreign governments have also shown concerns on the several data breaches. In October 2016 the European privacy regulators Article 29 Data Protection Working Party outlined concerns about the 2014 data breach as well as allegations that the company built a system that scanned customers' incoming emails at the request of U.S. intelligence services in a letter to Yahoo. They asked Yahoo to communicate all aspects of the data breach to the European Union authorities, to notify the affected users of the "adverse effects" and to cooperate with all "upcoming national data protection authorities' enquiries and/or investigations". Ireland's Data Protection Commissioner, (the lead European regulator on privacy issues for Yahoo because Yahoo's European headquarters are in Dublin), investigated the breach and issued a statement that "Yahoo's oversight of the data processing operations performed by its data processor did not meet the standard required by EU data protection law" and that "Yahoo did not take sufficient reasonable steps to ensure that the data processor it engaged complied with appropriate technical security and organisational measures as required by data protection law", although no fine was issued. Germany's Federal Office for Information Security criticized Yahoo following the December 2016 announcement, stating "security is not a foreign concept", and warned government and other German users to seek email and internet solutions from companies with better security approaches.

See also

[2012 Yahoo! Voices hack](#)

References

External links

[Yahoo's Account Security Issue FAQs](#)